Cahier des Charges
AI-Powered Phishing Simulation & Human Risk Scoring Platform

Aymane Ait Elmoumen
Khalil Laknifli
Ibrahim Ourhanim
Rihab Charouq

Année Universitaire 2025–2026

Table des matières

1 Contexte et objectifs **6**

1.1 Contexte 6

1.2 Objectifs généraux 6

1.3 Objectif scientifique (innovation) 6

1.4 Contribution scientifique détaillée 7

1.4.1 Innovation principale 7

1.4.2 Modèle de scoring innovant 7

1.4.3 Méthode d'adaptation intelligente 7

2 Périmètre du projet **8**

2.1 Utilisateurs cibles 8

2.2 Organisations ciblées 8

3 Fonctionnalités principales **8**

3.1 Génération intelligente de phishing 8

3.2 Adaptation comportementale 8

3.3 Campagnes de simulation 9

3.4 Analyse comportementale 9

3.5 Human Risk Scoring intelligent 9

3.6 Formation personnalisée 9

4 Architecture technique **9**

4.1 Architecture globale 10

4.2 Technologies 10

4.3 Architecture IA détaillée 10

4.3.1 Pipeline de génération d'emails 10

4.3.2 Pipeline de scoring 11

4.3.3 Système d'adaptation (Reinforcement Learning) 11

5 Sécurité et conformité **12**

6 Protocole expérimental **12**

6.1 Hypothèse de recherche 12

6.2 Objectif expérimental 12

6.3 Design expérimental 12

6.4 Méthodologie 13

6.5 Métriques scientifiques 13

6.5.1 Métriques comportementales 13

6.5.2 Métriques d'efficacité du modèle 13

6.5.3 Métriques pédagogiques 14

6.6 Analyse statistique 14

7 Planning et méthodologie de réalisation **14**

7.1 Phase 1 : Cadrage scientifique 14

7.1.1 Étape 1 : Définition de la contribution recherche 14

7.1.2 Étape 2 : Étude bibliographique 14

7.2 Phase 2 : Conception technique 15

7.2.1 Étape 3 : Architecture détaillée 15

7.2.2 Étape 4 : Conception du modèle de scoring 15

7.3 Phase 3 : Développement 16

7.3.1 Étape 5 : Développement Backend 16

7.3.2 Étape 6 : Développement IA 16

7.3.3 Étape 7 : Développement Frontend 16

7.4 Phase 4 : Expérimentation 17

7.4.1 Étape 8 : Tests utilisateurs réels 17

7.4.2 Étape 9 : Analyse scientifique 17

7.5 Phase 5 : Valorisation 17

7.5.1 Étape 10 : Rédaction article scientifique 17

7.5.2 Étape 11 : Préparation démonstration événement 18

8 Livrables attendus **18**

9 Innovation technique et différenciation **19**

9.1 Positionnement par rapport à l'état de l'art 19

9.1.1 Limites des solutions existantes 19

9.1.2 Innovations apportées par ce projet 19

9.2 Contribution scientifique originale 20

10 Perspectives d'évolution **20**

11 Équipe projet **20**

1 Contexte et objectifs

1.1 Contexte

Les attaques de phishing constituent aujourd'hui l'un des principaux vecteurs de compromission des systèmes d'information. Malgré l'existence de solutions techniques avancées, le facteur humain demeure le maillon le plus vulnérable.

Les organisations ont donc besoin d'outils intelligents capables de :

— simuler des attaques réalistes,

— mesurer le risque humain,

— adapter la formation en continu,

— améliorer la posture de cybersécurité globale.

1.2 Objectifs généraux

— Simuler des campagnes de phishing réalistes via l'IA générative.

— Évaluer le comportement des utilisateurs face aux attaques simulées.

— Calculer un **score de risque humain dynamique**.

— Proposer des **formations personnalisées automatisées**.

— Fournir une **plateforme visuelle professionnelle** adaptée aux démonstrations académiques et industrielles.

1.3 Objectif scientifique (innovation)

Ce projet introduit une contribution de recherche :

— Conception d'un **modèle de Human Phishing Risk Scoring basé Machine Learning**.

— Adaptation automatique des campagnes selon le comportement utilisateur.

— Évaluation expérimentale avec métriques statistiques.

Cette contribution vise une **publication scientifique** dans le domaine *AI for Cyberse-*

curity Awareness.

1.4 Contribution scientifique détaillée

1.4.1 Innovation principale

Le projet propose un **modèle de scoring prédictif de vulnérabilité humaine** basé sur l'apprentissage automatique, capable de :

- **Prédire la probabilité de clic** avant l'envoi d'une campagne de phishing.
- **Adapter dynamiquement** le niveau de difficulté des campagnes selon le profil comportemental de chaque utilisateur.
- **Optimiser les formations** en ciblant les vulnérabilités spécifiques identifiées par le modèle.

1.4.2 Modèle de scoring innovant

Le modèle de **Human Phishing Risk Score (HPRS)** combine :

- **Features comportementales** : historique de clics, temps de réaction, taux de signalement, patterns temporels.
- **Features contextuelles** : poste, département, ancienneté, historique de formations.
- **Features psychologiques inférées** : niveau de prudence, impulsivité, sensibilité aux différents types de phishing.
- **Algorithme ML** : Random Forest ou Gradient Boosting pour la classification multi-classe (faible, moyen, élevé, critique).

1.4.3 Méthode d'adaptation intelligente

Système d'adaptation basé sur **Reinforcement Learning** :

- L'agent RL apprend à ajuster les paramètres des campagnes (ton, urgence, complexité) pour maximiser l'efficacité pédagogique.
- Récompense : amélioration du score de risque après formation.
- Politique adaptative : ajustement en temps réel selon les réactions utilisateur.

2 Périmètre du projet

2.1 Utilisateurs cibles

— Employés d'entreprises

— Responsables cybersécurité (RSSI)

— Responsables IT / DSI

— Formateurs et équipes RH

— Chercheurs et étudiants

2.2 Organisations ciblées

— PME et grandes entreprises

— Banques et institutions financières

— Administrations publiques

— Universités et centres de recherche

3 Fonctionnalités principales

3.1 Génération intelligente de phishing

— Génération automatique d'emails réalistes via LLM.

— Styles variés : urgence, autorité, opportunité, curiosité.

— Personnalisation selon poste, département, langue et historique.

3.2 Adaptation comportementale

— Ajustement dynamique du niveau de crédibilité.

— Évolution des scénarios selon les réactions passées.

3.3 Campagnes de simulation

- Planification des campagnes.
- Envoi automatisé multi-canal (email, SMS, messagerie).
- Gestion des groupes d'utilisateurs.

3.4 Analyse comportementale

- Taux de clic.
- Temps de réaction.
- Signalement ou non.
- Historique d'évolution.

3.5 Human Risk Scoring intelligent

- Score individuel et organisationnel.
- Modèle ML utilisant :
  - fréquence des erreurs,
  - rapidité de réaction,
  - progression après formation.
- Classification : faible, moyen, élevé, critique.

3.6 Formation personnalisée

- Recommandations automatiques.
- Micro-learning ciblé.
- Suivi de progression.

4 Architecture technique

4.1 Architecture globale

— Frontend Web interactif.

— Backend API sécurisé.

— Moteur IA (LLM + modèle ML de scoring).

— Base de données chiffrée.

— Service d'envoi d'emails simulés.

4.2 Technologies

Frontend :

— React / Next.js

— Tailwind CSS

— Graphiques interactifs

Backend :

— Node.js ou Laravel

— API REST sécurisée

— Authentification JWT

IA :

— Modèle de langage pour génération d'emails

— Modèle Machine Learning pour scoring

— Analyse statistique des comportements

4.3 Architecture IA détaillée

4.3.1 Pipeline de génération d'emails

1. **Template selection** : sélection d'un template de phishing selon le style cible (urgence, autorité, etc.).
2. **LLM generation** : utilisation d'un LLM (GPT-4, Claude, ou modèle open-source)

pour générer le contenu personnalisé.

3. **Personalization** : adaptation selon profil utilisateur (poste, département, historique).
4. **Quality check** : validation de la crédibilité et cohérence de l'email généré.
5. **Landing page generation** : création automatique d'une page de simulation pour tracking.

4.3.2 Pipeline de scoring

1. **Feature extraction** : extraction des features comportementales, contextuelles et psychologiques.
2. **Feature engineering** : création de features dérivées (tendances, patterns temporels).
3. **Model inference** : calcul du score de risque via le modèle ML entraîné.
4. **Risk classification** : classification en 4 niveaux (faible, moyen, élevé, critique).
5. **Confidence score** : calcul de la confiance de la prédiction.

4.3.3 Système d'adaptation (Reinforcement Learning)

— **État (State)** : profil utilisateur actuel, historique comportemental, score de risque.

— **Actions (Actions)** : ajustement des paramètres de campagne (ton, urgence, complexité, type de phishing).

— **Récompense (Reward)** : amélioration du score de risque après formation, réduction du taux de clic.

— **Algorithme** : Q-Learning ou Policy Gradient pour optimiser la politique d'adaptation.

— **Exploration vs Exploitation** : balance entre tester de nouvelles stratégies et utiliser les stratégies efficaces.

Base de données :

— PostgreSQL

— Chiffrement des données sensibles

5 Sécurité et conformité

— Respect du RGPD.

— Anonymisation des données.

— Chiffrement en transit et au repos.

— Journalisation et contrôle d'accès par rôles.

6 Protocole expérimental

6.1 Hypothèse de recherche

H1 : L'utilisation d'un modèle ML de scoring prédictif permet d'identifier avec précision les utilisateurs à haut risque de phishing.

H2 : Les formations personnalisées basées sur le modèle de scoring réduisent significativement le taux de clic sur les emails de phishing simulés.

H3 : L'adaptation dynamique des campagnes via Reinforcement Learning améliore l'efficacité pédagogique comparée à des campagnes statiques.

6.2 Objectif expérimental

Évaluer l'efficacité du modèle de scoring prédictif, des formations personnalisées et du système d'adaptation intelligente.

6.3 Design expérimental

Type : Étude quasi-expérimentale avec groupe témoin.

Participants :

— Groupe expérimental : 50-100 utilisateurs avec système adaptatif.

— Groupe témoin : 50-100 utilisateurs avec campagnes statiques.

— Campagnes hebdomadaires.

6.4 Méthodologie

1. **Phase baseline** :
   - Envoi de campagnes de phishing standardisées.
   - Collecte des métriques comportementales initiales.
   - Calcul du score de risque initial pour chaque utilisateur.
2. **Phase intervention** :
   - Groupe expérimental : campagnes adaptatives + formations personnalisées.
   - Groupe témoin : campagnes statiques + formations génériques.
   - Collecte continue des données comportementales.
3. **Phase post-intervention** :
   - Nouvelle campagne de phishing standardisée pour les deux groupes.
   - Comparaison statistique avant/après.
   - Analyse de la rétention des apprentissages.

6.5 Métriques scientifiques

6.5.1 Métriques comportementales

- **Taux de clic (CTR)** : nombre de clics / nombre d'emails ouverts.
- **Temps de réaction** : temps entre réception et action (clic ou signalement).
- **Taux de signalement** : nombre de signalements / nombre d'emails reçus.
- **Score de risque moyen** : évolution du HPRS dans le temps.

6.5.2 Métriques d'efficacité du modèle

- **Précision du modèle prédictif** : capacité à prédire les clics (accuracy, precision, recall, F1-score).
- **AUC-ROC** : performance du modèle de classification du risque.
- **Corrélation prédiction-réalité** : corrélation de Pearson entre score prédit et com-

portement réel.

6.5.3 Métriques pédagogiques

— **Taux de complétion des formations** : pourcentage de formations complétées.

— **Amélioration du score** : différence de score avant/après formation.

— **Rétention** : maintien de l'amélioration après 1 mois.

6.6 Analyse statistique

— **Tests de significativité** : test t de Student pour comparaison des moyennes, test du chi-deux pour proportions.

— **Analyse de variance** : ANOVA pour comparer les groupes expérimental et témoin.

— **Modélisation** : régression linéaire pour identifier les facteurs prédictifs.

— **Visualisation** : graphiques d'évolution temporelle, heatmaps de corrélation, distributions.

— **Seuil de significativité** : $p < 0.05$ avec intervalle de confiance à 95%.

7 Planning et méthodologie de réalisation

7.1 Phase 1 : Cadrage scientifique

7.1.1 Étape 1 : Définition de la contribution recherche

— Affinement de l'innovation principale : modèle HPRS prédictif.

— Définition des hypothèses de recherche (H1, H2, H3).

— Identification de la nouveauté par rapport à l'état de l'art.

— Validation de la faisabilité technique et scientifique.

7.1.2 Étape 2 : Étude bibliographique

— Lecture et analyse de 10-15 articles scientifiques sur :

  — Phishing simulation et awareness training.

  - Human risk scoring en cybersécurité.
  - AI et Machine Learning pour cybersecurity awareness.
  - Reinforcement Learning pour adaptation comportementale.
- Rédaction d'un état de l'art structuré.
- Identification des gaps de recherche à combler.
- Définition du positionnement scientifique du projet.

7.2 Phase 2 : Conception technique

7.2.1 Étape 3 : Architecture détaillée

- Définition du flux de données complet (de la génération à l'analyse).
- Conception du pipeline IA (génération, scoring, adaptation).
- Modélisation de la structure de base de données (schéma relationnel).
- Définition des rôles utilisateurs et permissions.
- Spécification des APIs et interfaces.
- Diagrammes UML (cas d'usage, séquence, architecture).

7.2.2 Étape 4 : Conception du modèle de scoring

- Identification des variables comportementales à collecter.
- Définition des features pour le modèle ML.
- Choix de l'algorithme (Random Forest, XGBoost, Neural Network).
- Conception de la formule mathématique ou architecture du modèle.
- Définition des métriques d'évaluation du modèle.
- Prototype du modèle sur données synthétiques.

7.3 Phase 3 : Développement

7.3.1 Étape 5 : Développement Backend

— Mise en place de l'infrastructure (serveur, base de données).

— Développement de l'API REST sécurisée.

— Système d'authentification et gestion des utilisateurs.

— Module de gestion des campagnes (création, planification, envoi).

— Système de collecte et stockage des événements comportementaux.

— Tests unitaires et d'intégration.

7.3.2 Étape 6 : Développement IA

— Intégration du LLM pour génération d'emails.

— Développement du pipeline de génération personnalisée.

— Implémentation du modèle de scoring ML (entraînement et inference).

— Développement du système d'adaptation par Reinforcement Learning.

— Optimisation des performances (latence, coûts).

— Tests de validation du modèle.

7.3.3 Étape 7 : Développement Frontend

— Interface de dashboard administrateur (visualisation des scores, campagnes).

— Interface utilisateur (score personnel, formations, historique).

— Visualisations interactives (graphiques d'évolution, heatmaps).

— Interface de création et gestion de campagnes.

— Module de formation personnalisée.

— Design responsive et tests d'utilisabilité.

7.4 Phase 4 : Expérimentation

7.4.1 Étape 8 : Tests utilisateurs réels

- Recrutement de participants (étudiants, club informatique, volontaires).
- Configuration des campagnes de test.
- Exécution de la phase baseline.
- Application des formations personnalisées.
- Exécution de la phase post-intervention.
- Collecte continue des données :
  - Taux de clic.
  - Temps de réaction.
  - Progression des scores.
  - Feedback utilisateurs.

7.4.2 Étape 9 : Analyse scientifique

- Nettoyage et préparation des données.
- Calcul des métriques scientifiques (CTR, précision, AUC-ROC).
- Tests statistiques (test t, ANOVA, chi-deux).
- Visualisations (graphiques d'évolution, distributions, corrélations).
- Interprétation des résultats.
- Validation des hypothèses de recherche.
- Identification des limites et biais potentiels.

7.5 Phase 5 : Valorisation

7.5.1 Étape 10 : Rédaction article scientifique

- Structure de l'article :
  - **Introduction** : contexte, problème, objectifs.

  - **État de l'art** : revue de littérature, positionnement.
  - **Méthodologie** : architecture, modèles, protocole expérimental.
  - **Résultats** : métriques, analyses statistiques, visualisations.
  - **Discussion** : interprétation, limites, perspectives.
  - **Conclusion** : contributions, travaux futurs.
- Révision et amélioration itérative.
- Préparation pour soumission (format de conférence/journal).

7.5.2 Étape 11 : Préparation démonstration événement

- Création d'un scénario de démonstration live.
- Préparation d'un dashboard impressionnant avec données réelles.
- Développement de slides professionnelles.
- Vidéo de démonstration (optionnel).
- Documentation utilisateur et technique finale.
- Préparation de la présentation orale.

8 Livrables attendus

- Plateforme web fonctionnelle complète.
- Modèle IA entraîné et validé (HPRS + système d'adaptation).
- Documentation technique complète (architecture, API, déploiement).
- Documentation utilisateur (guides administrateur et utilisateur final).
- Jeu de données de démonstration avec résultats expérimentaux.
- Rapport scientifique avec résultats expérimentaux et analyses statistiques.
- Article scientifique prêt pour soumission.
- Présentation et démonstration pour événement académique.

9 Innovation technique et différenciation

9.1 Positionnement par rapport à l'état de l'art

9.1.1 Limites des solutions existantes

Les solutions actuelles de simulation de phishing présentent plusieurs limitations :

— **Scoring statique** : utilisation de règles simples (taux de clic, nombre d'erreurs) sans prédiction.

— **Campagnes non adaptatives** : mêmes scénarios pour tous les utilisateurs, sans personnalisation.

— **Formations génériques** : contenu identique pour tous, sans ciblage des vulnérabilités spécifiques.

— **Absence de modèles ML** : pas d'apprentissage automatique pour améliorer l'efficacité.

9.1.2 Innovations apportées par ce projet

1. **Modèle prédictif de vulnérabilité** :
   — Prédiction de la probabilité de clic **avant** l'envoi de la campagne.
   — Identification proactive des utilisateurs à risque.
   — Modèle ML multi-features (comportemental, contextuel, psychologique).
2. **Adaptation dynamique par Reinforcement Learning** :
   — Ajustement automatique des paramètres de campagne selon les réactions.
   — Optimisation continue de l'efficacité pédagogique.
   — Apprentissage des stratégies les plus efficaces par utilisateur.
3. **Scoring multi-dimensionnel** :
   — Combinaison de features comportementales, contextuelles et psychologiques.
   — Classification fine en 4 niveaux avec scores de confiance.
   — Évolution temporelle et prédiction de tendances.

4. **Formation ciblée par IA** :
   - Recommandations automatiques basées sur le modèle de scoring.
   - Contenu adapté aux vulnérabilités spécifiques identifiées.
   - Suivi de l'impact des formations sur le score de risque.

9.2 Contribution scientifique originale

Ce projet apporte une contribution originale à la recherche en combinant :

- **Machine Learning** pour le scoring prédictif de vulnérabilité humaine.
- **Reinforcement Learning** pour l'adaptation dynamique des campagnes.
- **Évaluation expérimentale rigoureuse** avec protocole scientifique et analyses statistiques.
- **Validation empirique** sur données réelles avec groupe témoin.

Cette combinaison n'a pas été explorée dans la littérature existante, ce qui justifie une publication scientifique.

10 Perspectives d'évolution

- Intégration avec SIEM / SOC pour corrélation avec incidents réels.
- Extension multi-canal avancée (SMS, Teams, Slack, appels vocaux).
- Benchmark inter-organisations avec données anonymisées.
- Publication scientifique internationale (conférence ou journal).
- Extension à d'autres types d'attaques (social engineering, vishing).
- Modèle prédictif de vulnérabilité pour nouveaux employés.

11 Équipe projet

Prénom	Nom
Aymane	Ait Elmoumen
Khalil	Laknifli
Ibrahim	Ourhanim
Rihab	Charouq